

基于智能卡的安全登录系统的设计*

张帆, 张申生, 唐业, 戴伟

(上海交通大学信息安全工程学院, 上海交通大学计算机集成制造技术实验室, 上海 200030)

摘要: 本文提出了一种利用 USB 智能卡, 把硬件加密, 身份验证与 Windows2000 登录控制结合起来的用户识别技术方案。本文首先简单介绍了传统的 Windows2000 的用户名密码登录方式以及 Windows2000 对智能卡登录的支持, 然后提出并实现了一个利用 USB 智能卡技术来定制的 Windows2000 用户识别的技术方案, 从而有效地提升了 Windows 登录的安全性和适应性。

关键词: GINA (图形化身份认证与鉴别); Smart Card (智能卡); SAS (安全注意序列); GUID (全局唯一标志符)

Design of Secure Logon System Based on Smart Card

ZHANG Fan, ZHANG ShenSheng, TANG Ye, DAI Wei

(School of Information Security Engineering, Shanghai Jiao Tong University, Computer Integrated Technology Lab in Shanghai, Shanghai 200030)

Abstract: This paper describes a solution of user identification system which makes use of USB smart card and combines the technology of Windows2000 log-on control, authentication and hardware encryption. It firstly simply introduces how to log on Windows2000 by the normal method of username and password. And then a Windows2000 user identification system is implemented by means of USB key technology, which can efficiently improves the security and flexibility of Windows log-on.

Key word: GINA (Graphical Identification and Authentication); Smart Card; SAS (Secure Attention Sequence); GUID (Globally Unique Identifier);

1 引言

随着我国数据电子化和网络化程度的不断加深, 用户登录和用户身份认证问题也愈来愈引起人们的重视。传统的身份认证机制都是建立在口令的识别基础之上的。这种以口令为基础的常规身份认证方式, 很易导致用户的账户密码被窃取、口令被修改, 以及在信息传输过程中的重要信息被窃取等问题。目前被广泛使用的 windows2000 操作系统采用的也是基于口令密码的用户身份认证技术。这种传统的基于口令密码的身份认证只能提供最基本的身份识别, 不能抵御口令猜测攻击, 其安全性很难得到保障。

使用智能卡进行用户的身份认证, 可以有效地限制非法用户的系统登录。具有非对称加密能力的智能卡能够有效地保证密钥的安全生成、存储和使用。采用智能卡的一种比较安全的方式是把私密信息存在 Smart Card 上 (而非易于受到黑客攻击的 PC 机中), 在 Smart Card 中完成特定算法的加密、解密和身份认证功能, 减少由于机密信息的流动而造成的不安全性。PIN (个人识别码或口令) 可以保证 Smart Card 对持卡人的身份认证, 防止 Smart Card 丢失后客户私密信息的非法使用, 实现双重安全功能。本文提出的基于智能卡的安全登录系统的

基金项目: 国家 863 项目 “面向大规模定制的协同商务与集成设计系统” (编号 2001AA412010) 资助。

作者简介: 张帆 (1978~), 男, 硕士生, 上海交通大学 CIT 实验室, 研究方向: 信息安全。

设计方案，也是基于以上的智能卡使用方式的。

本方案采用了两重验证方式，将每个用户的密码信息加密以后分别存储在智能卡，域服务器 AD 和中心数据库中，登录与硬件(USB 智能卡)绑定，一级验证由智能卡完成，二级验证和登录由 Windows 操作系统自动完成。登录的口令可以设计得相当复杂，所以大大提高了系统的安全性。同时，由于实现了一卡多身份的对应，系统的灵活性也有了一定的提高。

本文将首先讲述 windows2000 对智能卡登录方式的支持，然后分别介绍安全登录系统服务器端和客户端的设计原理和主要功能，最后给出总结和展望。

2 windows2000 对交互式登录的支持

Winlogon 是 Windows 2000/NT 操作系统提供交互式登录支持的组件。Winlogon 有三个组成部分：可执行文件 winlogon.exe，提供图形界面认证功能的动态库 Gina Dll，以及一些网络服务提供动态库 Network Provider Dll。

我们熟悉的 Windows2000 登录方式是用户名-密码方式，实际上 Windows2000 还允许用户自己定制特殊的登录方式。对此，我们只需要对 GINA Dll 进行定制就可以实现完全客户化的智能卡登录方式。事实上，微软公司就是使用了系统默认的 msgina.dll 来实现 windows 交互式登录界面。

GINA^[1] (Graphical Identification and Authentication，图形身份验证)是微软 Windows2000 操作系统负责登录的功能模块。这个模块按照验证策略执行用户交互。GINA 是在系统引导过程的早期由 Winlogon 加载的一个可替换的动态连接库，它提供了 Winlogon 用户标识和验证用户的输出函数，并且必须遵守保证系统安全的一系列完整性规则。当用户登录时，它的作用是收集用户名，密码，域等用于标识用户身份的信息，并把这些信息填入 LSA（本地安全权限）进行验证。作为 Windows2000 操作系统的核心安全组件，LSA 负责在本地登录和远程登录中验证用户身份，并维护本地安全策略。LSA 通过调用的特定的验证程序包来完成这些任务^[2]。

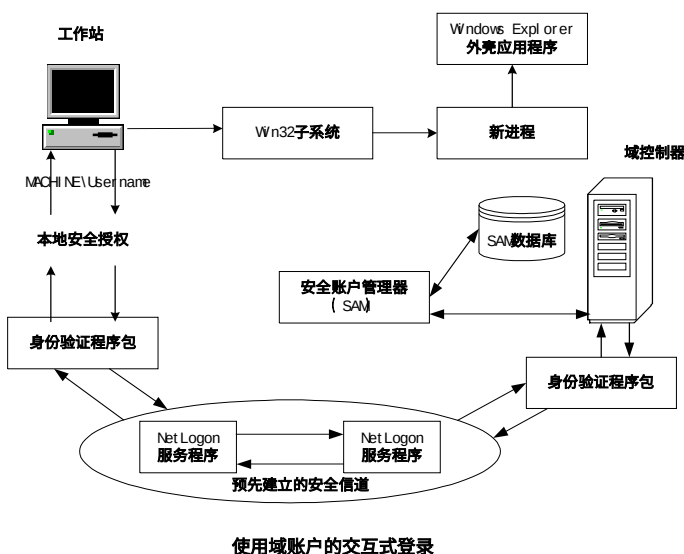


图 1

在远程登录的过程中，LSA 调用 NetLogon 服务程序向域服务器发送验证程序包，由域服务器进行域身份验证。如图 1 所示，当验证程序包在用户验证时接受或者拒绝登录数据后，其结果都会通过 LSA 返回到 GINA，由 GINA 向用户显示验证是成功还是失败。GINA 还

这些结果返回到 Winlogon。如果验证程序包成功的验证了用户身份，那么 Winlogon 就会为用户创建一个窗口工作站和桌面，并启动用户将来与计算机进行交互的外壳进程。

我们采用自己开发 GINA 的方案，使用 USB Smart Card 作为存储用户信息并且用来登录的硬件设备。其中用户信息是指该用户的一系列登录用户名和密码对。

3 方案设计和处理流程

本方案所提出的使用智能卡进行交互式登录的过程与传统的基于口令的登录过程有相似的地方。简单的流程可以说明如下^[3]：用户将智能卡插入 USB 口就可以启动登录的一系列操作，这会产生一个 SAS，相当于键入了 CTRL+ALT+DEL。一旦接收到 SAS，客户端应用程序首先判断智能卡是否是由指定厂商生产的，明确类别以后就切换到 Winlogon 桌面，调出 GINA，显示一个对话框要求输入智能卡的 PIN。用户输入 PIN 后，若 PIN 正确，GINA 就从智能卡的特定区域解密出用户的所有帐号信息，用户选择其中的一个，请求进行登录。值得注意的是，在发送登录请求到域服务器之前，LSA 先向本地 SAM 数据库询问用户帐户的详情以及匹配的密钥。由于我们是采用的域服务器的验证方式，本地没有相应的 windows 账户，SAM 无法找到匹配的帐户信息，LSA 就去调用 Netlogon，通过 Netlogon 预先建立的安全通道，把用户的登录信息送到域服务器上去验证，如果域服务器在 AD(Active Directory)找到了账户信息，它就向 MSV1_0 验证程序包返回用户的 SID (The Security Identifier) 和用户所在组的 SID，并再次通过 Netlogon 把验证结果返回到 LSA。如果域服务器没有找到账户信息，验证失败结果也要返回到 LSA。客户端程序从 LSA 中获得验证结果，并把结果返回给用户，同时对智能卡进行相应的操作，如锁定智能卡等。

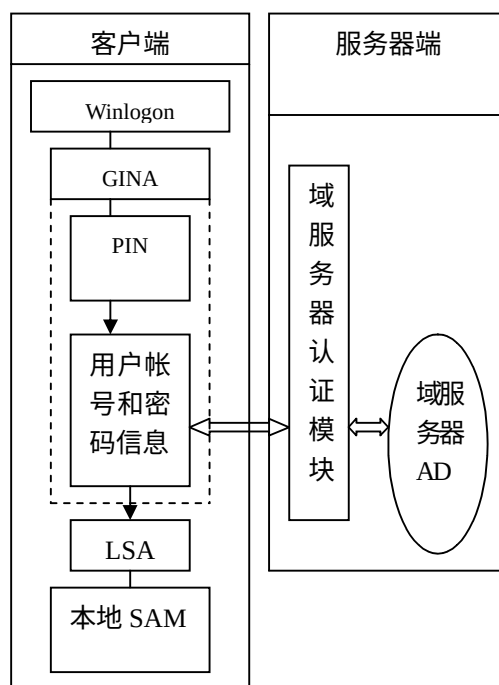


图 2

域服务器端管理工具 SLogonConsole

域服务器端管理工具 SLogonConsole 是一个所有的智能卡以及智能卡内置用户帐号进行统一管理的工具。域服务器端管理工具 SLogonConsole 是和域服务器上的 Active Directory 紧密地结合在一起的。在本方案中，智能卡中储存的用户帐号信息是和 Windows 域帐号紧密地绑定在一起的。任何对智能卡用户帐号的操作（添加，删除，修改密码），都会相应的在域服务器上的 Active Directory 中进行。SLogonConsole 利用图形化的界面，使得用户免去了对 AD 的直接操作，大大提高了系统的方便性。SLogonConsole 提供的主要的功能有验证智能卡的外部密钥，发行新的智能卡，生成新的公私钥对，口令解锁，控制允许登录的计算机以及恢复智能卡。

①通过外部密钥验证

外部密钥验证是对智能卡进行任何读写操作之前必须要通过的验证。只有通过了外部密

钥验证，才能够正常的运行 SLogonConsole，否则用户没有运行服务器端管理工具 SLogonConsole 的权利。一般来讲，外部密钥的持有者通常是和 Windows2000 域管理员身份集成在一起的。在检验外部密钥之前，SLogonConsole 还自动检验当前操作系统登录用户的权限。如果操作系统登录用户不是域管理员，那么外部密钥验证应用程序将无法启动，用户也就无法通过外部密钥验证，自然也就没有办法使用 SLogonConsole。外部验证密钥的长度为 16 个字符，由智能卡生产厂商规定的。域服务器上也安装客户端登录工具以后，智能卡外部密钥验证，口令验证，卡内身份验证以及域管理员身份验证的多重验证机制，将大大的提高域服务器的安全性。

②发行新的智能卡

当有新用户提出申请时，域管理员根据他的需求并且结合用户的实际身份为他生成一张智能卡。域管理员可以选择域服务器 Active Directory 中的已存在的账号，或者根据用户需要手动创建一个新的账号，把它加入到一个全新的 USB 智能卡中，生成一张普通登录卡。SLogonConsole 在向智能卡中写入登录账号的同时，根据一定的密钥生成算法，生成一定长度的密码，作为新的账号的密码。如果该账号在原来的 AD 中已经存在，那么生成的新密码将会覆盖原来的旧密码。登录账号和密码存储在智能卡中特殊的文件分区里，只有通过一定的密钥验证才能够读取。由于智能卡中有具有相当运算能力的 CPU，因此，登录密码将会由一定的加密算法加密以后再保存，系统的安全性也大大提高了。用户使用这张卡中的用户帐号信息就登录到规定的机器上去了。

域管理员还需要为自己创立管理员卡以便自己能够登录域服务器。管理员卡中设有特定的标示，如果该管理员隶属于域上的系统管理员成员组，那么用户使用该智能卡，可以登陆域服务器启动 SLogonConsole 进行账号管理，同时还可以在其他的客户机上进行登录和解除其他普通用户锁定计算机的操作。

③生成新的公私钥对

公私钥对是公钥密码学中的概念。它为支持 PKI（Public Key Infrastructure）体系而生成，主要用于 PKI 体系下文件的加密，解密，签名，签名验证。生成的公私钥对存储在智能卡的不同文件区，可以供用户使用。

④口令解锁

当用户由于忘记自己的口令，而多次输入错误的口令，造成该口令被锁死，用户不能再使用该智能卡，这时可用 SLogon Console 的口令解锁工具，解锁被锁定的智能卡。

⑤控制允许登录的计算机

SLogon Console 可以控制智能卡只能在某台或者某些计算机登录。在管理员为用户发卡时，根据用户的实际需要，控制用户能够登录的计算机，提高整个系统的安全性

⑥恢复智能卡

当智能卡不慎丢失或者损坏以后，可以从数据库中恢复以前的智能卡，避免因智能卡丢失以后文件不能解密，用户配置信息丢失等损失。

客户端登录程序 SLogon

客户端登录程序 SLogon 是基于 Windows 的 GINA 对自定义的系统登录流程的支持而开发的，GINA 原理在前文已经详细讲述。客户端登录程序 SLogon 是和服务器端的

SLogonConsole 紧密地联系在一起的，SLogonConsole 对智能卡进行配置，SLogon 负责验证智能卡口令,从而正确地读取帐户信息，然后送入到 Windows 的用户验证接口。SLogon 提供的主要功能包括：USB 智能卡识别，智能卡 PIN 验证，一卡多身份以及智能卡插拔锁定与解锁等。

①USB 智能卡识别

要想在客户端正确使用 USB 智能卡，必须先客户端安装 USB 智能卡的驱动程序。这样客户端能正确地在本地注册表写入该厂商提供的 USB 智能卡的 GUID。完成安装 SLogon 程序之后，系统自动重新启动。SLogon 屏蔽掉 windows 默认的用户名-密码方式登录，强制用户必须使用特定厂商提供的 USB 智能卡进行登录。当用户插入 USB 智能卡时，SLogon 自动进行智能卡识别检查，如果所用的智能卡不是特定厂商生产的，或者插入的是其他 USB 设备，则系统就会出现错误提示。如果所用智能卡满足要求，系统提示需要输入 PIN 码进行验证登陆。

②智能卡 PIN 验证

对于智能卡的使用用户来说，PIN 是标示用户身份的标志之一。正确的用户 PIN 和实际的智能卡硬件结合在一起能够比较精确的标示一个用户的真实身份。用户输入的 PIN 通过 GINA 送入到智能卡中，智能卡调用特定的验证程序在智能卡内部进行验证。验证通过以后，就可以取得保存在当前智能卡中的所有 Windows 登录账号和密码信息。如果用户输入口令错误，多次验证失败以后，智能卡将被锁定，从而需要管理员解锁以后才能够恢复正常的的使用。这样的锁定机制有效的防止了用户进行重复攻击的可能。另外，智能卡本身具有一定的加密功能，所有的用户帐号和密码信息都是加密过的，即使智能卡丢失，其他用户也没有办法读取智能卡内的用户信息。

③一卡多身份

所谓一卡多身份，指的是一张智能卡中储存了多个用户帐号和密码对，每一对用户帐号和密码标示了一个用户的特定身份。一个特定的用户，他既可以是该域的域管理员，具有较高的系统管理权限，也可以是普通的 USER 或者 GUEST,只有较低的使用权限。在支持智能卡本地登录的方式下，该用户也可以是本地（Local Machine）的管理员或者普通用户。如图 2 所示不同的用户身份，通过智能卡硬件以及 PIN，和真实的用户形成了多对一的映射。一卡多身份的技术，一方面有效地解决了账号的管理问题，使得同一个用户无需再记住多个不同的登录账号信息，另一方面有效的控制了登录用户的权限。

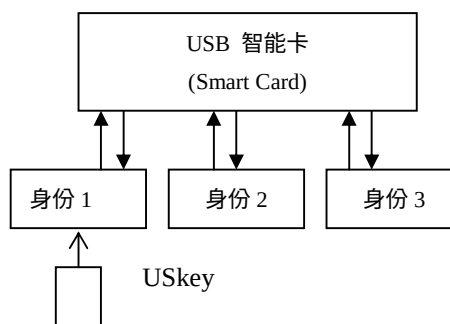


图 3

④智能卡插拔锁定与解锁^[4]

智能卡是用户身份的象征，只有具有智能卡的用户才能够使用特定的计算机，当用户因特殊原因需要离开计算机时，用户需要拔出智能卡，此时 SLogon 客户端程序将会监测到由 USB 口发出的设备移出(DEVICEREMOVAL)消息，该消息是广播消息，但是附带了设备变更时间发起者智能卡的 GUID，因此系统能够识别出是智能卡插拔还是其他的 USB 设备的插拔。根据这个消息，智能卡拔出以后，系统进入锁定状态。同时记录下锁定人的账号信息

以及锁定时间等相关信息。当用户回到计算机旁，重新插入智能卡时，系统同样能够监测到类似的设备到达(DEVICEARRIVAL)消息，提示用户输入智能卡的口令 PIN。如果口令验证成功，系统将会验证解锁人的身份。如果验证成功，系统将解除锁定，否则继续保持锁定状态。多次尝试解除锁定失败将会导致智能卡锁死。

智能卡插拔锁定与解锁技术，大大的提高了用户使用的方便性，同时对安全性也有一定程度的保障。

4 总结与展望

在我们的系统中，硬件采用低成本、便携带、易使用的 USB 卡设备。网络管理员为每一位要登录网络中某台机器的用户颁发一个 USB 卡，卡内存放着该用户多个身份账号。系统根据用户输入的智能卡 PIN 口令和从硬件中读取的用户帐号信息（用户名和密码）来判断用户身份的合法性。这种基于硬件的双重验证方式可以方便地和其它认证系统结合使用，极大的提高了系统的安全性。该方案成本低廉，扩展性好，非常适合中小公司内部局域网的统一管理。

本方案经过扩展，还可以结合数字证书技术使用户登录所有系统中的授权应用。这时身份认证系统的组成模块包括客户端、权威认证中心 CA 和应用服务器。通过使用该身份认证系统，用户可以方便地利用公钥技术和证书机制实现安全可靠的认证功能，从而登录到应用服务器上^[5]。

参考文献

- [1] Ben Hutz, Jack Fink. The Essentials of Replacing the Microsoft Graphical Identification and Authentication Dynamic Link Library. Microsoft Corporation Published June 2001
- [2] Internet Security Systems 公司. Windows2000 安全技术参考. 北京 :机械工业出版社, 2001
- [3] Microsoft Platform SDK Documents
- [4] David A. Solomon, Mark E. Russinovich. Windows2000 内部揭密. 北京 :机械工业出版社, 2001
- [5] Roberta Bragg, 《Windows 2000 安全技术》，清华大学出版社，2002—1